Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

TEAM DETAILS

S.NO	NAME	COLLEGE	CONTACT
1	SANFIYA. R	St. Joseph's College for Women	sanfiyasanfiya65@gmail.com
2	YAZHINNI. B	St. Joseph's College for Women	yazhinnib6@gmail.com
3	SHEKKINA. S	St. Joseph's College for Women	shekkinas312@gmail.com
4	DHARSHINI.V	St. Joseph's College for Women	dharshinivaradhu@gmail.com

INTRODUCTION

In today's digital world, technology is changing very quickly, and organizations face many cyber threats. Cyberattacks are increasing, so it is very important for companies to respond to security incidents quickly and effectively. This helps protect sensitive data, digital assets, and the trust of customers and stakeholders. To solve this problem, this project proposes the development of an AI-driven incident response platform that helps cybersecurity teams automate and improve incident detection, analysis, and response.

In the modern digital environment, the traditional network boundary is no longer effective. Many organizations now use cloud services, remote work, and personal mobile devices (BYOD). Because of this, company resources are not limited to a single office location anymore. The old "castle-and-moat" security model, where users inside the network are automatically trusted, is no longer safe. Organizations now need better ways to protect their data from different devices, locations, and users. Security systems must move from location-based security to identity-based security that checks every access request in real time.

This project focuses on designing and implementing a context-aware access control system to solve this problem. Instead of only checking a username and password, the system will analyze several factors before allowing access. These factors include the user's identity and role, the security condition of their device (such as updates, encryption, and management), their location, and the risk level of the application they want to access. By analyzing all these factors together, the system can decide whether to allow full access, give limited access, request extra verification such as multi-factor authentication, or completely block the request.

The main goal of this project is to create a security system that is both strong and easy to use. For example, if a trusted employee accesses a low-risk application from a secure company laptop inside the office network, they can log in easily. However, if the same employee tries to access a sensitive financial system from an unsecured personal device in another country, the system may ask for extra verification or block the access. This smart and adaptive security approach reduces cyber risks, protects important data, and supports a safe and productive work environment for modern employees.

Abstract:

In recent years, organizations have started using many modern technologies such as cloud services, mobile devices, and hybrid work models where employees work both from the office and from home. Because of this change, the traditional network boundary that once protected company systems is no longer effective. In the past, companies protected their systems by securing the internal network, assuming that users inside the network were safe and trustworthy. However, this approach does not work well anymore because employees now access company resources from different locations, devices, and networks.

As a result, organizations find it difficult to protect their sensitive data and digital resources. The number of possible cyber threats has increased because attackers can now target systems through many different paths. Threats may come from infected devices, unsafe internet connections, stolen user credentials, or even malicious insiders within the organization. In such a complex environment, traditional security systems that only allow or deny access based on simple rules are no longer strong enough to handle modern cyber risks.

Because of these challenges, organizations need a modern and dynamic security system that can analyze every access request carefully before allowing entry. Instead of making simple decisions based only on a username and password, the system should evaluate the full situation surrounding each request. This means understanding the context in which a user is trying to access a system. A real-time decision should be made by checking several factors together so that security becomes smarter and more reliable.

This project focuses on designing and implementing a context-aware access control system that considers multiple important factors before allowing access. These factors include the user's identity, the security condition of the device being used, the geographic location of the user, and the risk level of the application they want to access. For example, a device that is updated, encrypted, and managed by the organization will be considered safer than an unknown personal device. Similarly, accessing a system from a trusted location may be considered lower risk compared to accessing it from an unfamiliar location.

Use Case Scenarios:

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to use the company ERP system to process the monthly payroll. The user connects from a remote location using a company laptop. After opening the ZPA Client Connector, the user logs in through Azure Active Directory with Multi-Factor Authentication (MFA). ZPA checks the user's identity, group membership (Finance_ERP_Users), device security (antivirus running and disk encryption enabled), and connection details. After verification, the system allows the user to access only the ERP application through a secure micro-tunnel.

The user can work in the ERP system but cannot see or access other internal systems like development servers or the HR database.

Output:

- User is authenticated and authorized using identity and group membership
- A secure micro-tunnel is created only for the ERP application
- Other internal systems remain hidden and cannot be accessed

Scenario 2: Contractor Access to Specific Project Repository

A software contractor is hired for three months and needs access to a specific Git repository stored on an internal server. The contractor is added as a guest user in the identity system and placed in the Project_X_Contractors group. When the contractor connects using the ZPA client, the system checks the user's identity and device security (OS updates and firewall status). ZPA allows access only to the Git repository using port 22 (SSH) or port 443 (HTTPS) during working hours (9 AM – 5 PM). The contractor can clone, push, and pull code but cannot see or connect to other internal resources such as the company intranet or file servers.

Output:

- Access is limited by time and role
- Contractor can access only the Git repository
- Access to other internal systems is completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company Vice President (VP) needs to open confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center in another country using a company tablet. After opening the ZPA Client Connector, the user logs in through Azure Active Directory with MFA. ZPA checks the user's identity, executive group membership, and device security, which are valid. However, the login location is an unusual foreign country and the data being accessed is highly sensitive. This increases the risk level. The system allows access to the SharePoint site but adds restrictions. The user can only view the documents; downloading or printing is disabled. The session is monitored for unusual activity such as large downloads. A security alert is also sent to the security team.

Output:

- User is authenticated with MFA but flagged due to unusual location
- Read-only access is allowed; download and print are blocked
- Security team receives an alert for the high-risk login

Scenario 4: Remote Support Technician Access to Internal Tools

An IT support technician needs to access the company ServiceNow system and a remote desktop tool to help an employee. The technician connects from home using a company desktop computer and logs in through Azure Active Directory with MFA using the ZPA Client Connector. ZPA checks the technician's identity, group membership (IT_Support), device security, and connection location (home office approved for IT staff). Since everything meets the security requirements, the system provides secure micro-tunnel access to ServiceNow and the remote desktop jump host. The technician can do their support work but still cannot access other systems like finance databases, HR records, or source code repositories.

Output:

- User is authenticated and authorized with trusted conditions
- Secure micro-tunnels created for ServiceNow and the remote desktop tool
- Only necessary access is given; other systems remain hidden

Scenario 5: High-Risk Application Access from a Low-Trust Location

A marketing employee needs to update a campaign in the company Salesforce system. The user connects from a coffee shop using a company smartphone. After opening the ZPA Client Connector, the user logs in through Azure Active Directory with MFA. ZPA verifies the user's identity, group membership (Marketing_Salesforce_Users), and device security. However, the connection is through public Wi-Fi, which is considered high risk. Instead of blocking access completely, the system uses browser isolation. The Salesforce session runs in a secure temporary container so that no data is stored on the phone or exposed to the public network.

Output:

- User is authenticated and device is secure, but network is high-risk
- Access is provided through secure browser isolation
- Session runs in a protected container with restrictions on copy, paste, and downloads

STAGE 1

Title of the Project:

Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

Overview:

The project "Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk" aims to enhance the security of modern digital environments by implementing intelligent and adaptive access control mechanisms. With the rapid growth of cloud computing, remote working models, mobile devices, and web-based applications, organizations are increasingly allowing users to access systems from different networks and locations. This shift has significantly expanded the attack surface and introduced new security challenges. Traditional access control systems that rely mainly on usernames and passwords or fixed network boundaries are no longer sufficient to protect sensitive organizational resources.

In a traditional security model, once a user successfully logs in, they are often granted broad access to systems and applications without considering the conditions under which the access request is made. This approach can lead to serious security risks if a user's credentials are compromised, if the device being used is infected with malware, or if the access request comes from an unusual or unsafe location. To overcome these limitations, modern cybersecurity practices emphasize context-aware access control, where multiple contextual factors are evaluated before granting access to resources.

This project focuses on designing a context-aware access control system that evaluates four major factors: user identity, device posture, location, and application risk level. These factors together provide a comprehensive understanding of the security context of each access request.

The first factor, user identity, ensures that the person requesting access is a legitimate and authorized user. Identity verification is usually performed through authentication mechanisms such as passwords, single sign-on (SSO), and multi-factor authentication (MFA). By confirming the user's identity, the system ensures that only recognized individuals can attempt to access organizational applications.

The second factor, device posture, refers to the security status of the device used to access the system. The system checks whether the device complies with security requirements such as having updated antivirus software, operating system patches, firewall protection, and proper device management policies. If the device does not meet the required security standards, the system may restrict or completely block access to protect sensitive resources.

The third factor, location, analyzes where the access request originates. This includes checking whether the user is connecting from a trusted corporate network, a known geographic region, or an unfamiliar or suspicious location. Access requests from unusual locations may trigger additional verification steps or be denied altogether. This helps prevent unauthorized access attempts from malicious actors located in different regions.

The fourth factor, application risk, evaluates the sensitivity and importance of the application being accessed. Some applications contain highly confidential data, such as financial records or customer information, while others may have lower security requirements. By understanding the risk level of each application, the system can apply stricter access policies to critical applications and more flexible policies to less sensitive ones.

By combining these contextual factors, the system can dynamically make intelligent access decisions. For example, if a user logs in from a trusted device and location, access may be granted smoothly. However, if the same user attempts to log in from an unknown device or unusual location, the system may require additional authentication or temporarily block access. This adaptive approach improves security while still maintaining user convenience.

The project also highlights the importance of implementing Zero Trust security principles, where every access request is continuously verified regardless of whether it originates from inside or outside the organizational network. Instead of assuming that internal users are automatically trusted, the system evaluates every request based on contextual information.

The main objective of this project is to design and demonstrate how context-aware access controls can be applied to strengthen organizational security. By incorporating identity verification, device health checks, location monitoring, and application risk evaluation, the system creates a layered security model that significantly reduces the chances of unauthorized access and data breaches.

List of Vulnerability Table:

S.No	Vulnerability Name	CWE No
1	Cross-site scripting (Stored)	79
2	Broken Access Control	285
3	SQL Injection	89
4	Broken Authentication	285
5	Insecure Direct Object Reference	639
6	Security Misconfiguration	732
7	Cross-Site Request Forgery	352
8	Cleartext Transmission of Sensitive Information	319
9	Clickjacking	1021
10	Web server allows password auto-completion	310
11	Cross-site scripting (DOM-based XSS)	79
12	JQuery 1.2 < 3.5.0 Multiple XSS	79
13	Information Exposure – Internal IP Disclosure	200
14	Information Exposure – SSL Issues	200
15	Information Exposure – HTTP Issues	200
16	OS Identification Failed	200

REPORT

1. Vulnerability Name: Cross-site scripting (Stored)

CWE/CVE: 79

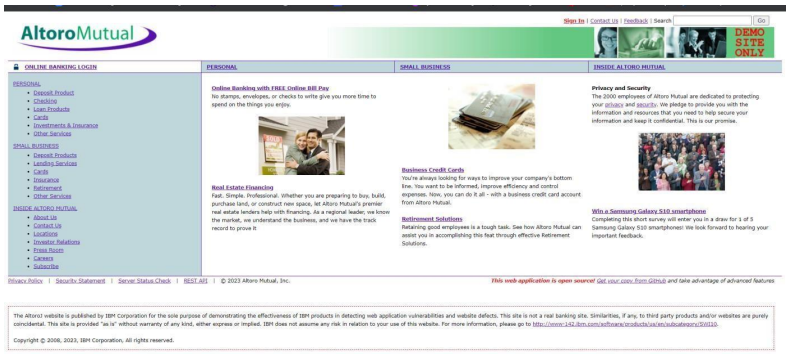
OWASP Category: A03:2021 – Injection

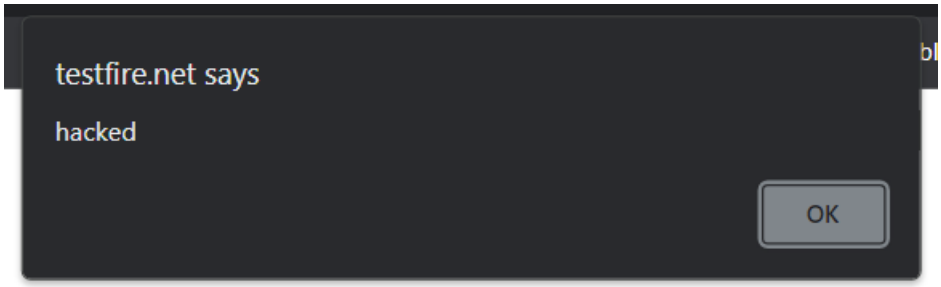
Description

Stored cross-site scripting occurs when malicious scripts are injected into a vulnerable web application and stored in a database or other persistent storage. When users access the affected page, the malicious script executes in their browser, potentially allowing attackers to steal data or perform unauthorized actions.

Business Impact

Stored XSS can allow attackers to perform privileged operations on behalf of legitimate users. If an administrator or privileged user accesses the compromised page, attackers may gain access to sensitive information, modify system data, or compromise the entire application.





2. Vulnerability Name: Broken Access Control

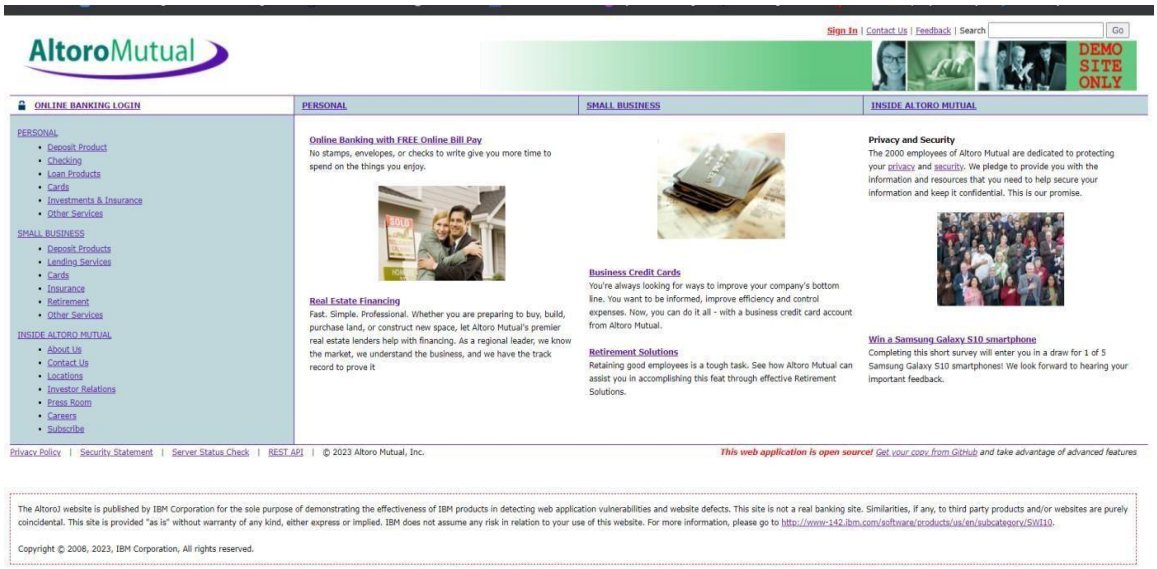
CWE: 285

Description

Broken access control occurs when authorization checks are not properly implemented, allowing users to access resources or perform actions that they are not authorized to perform.

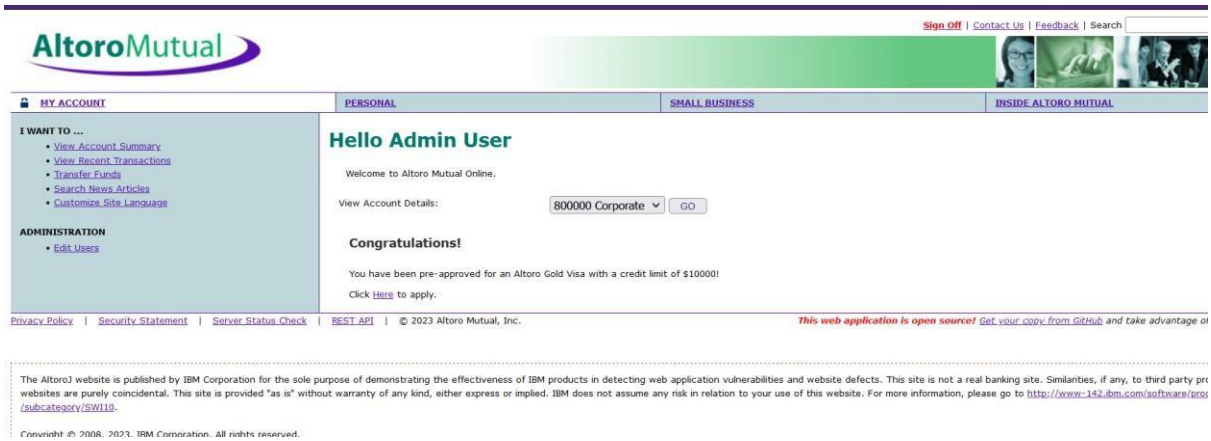
Business Impact

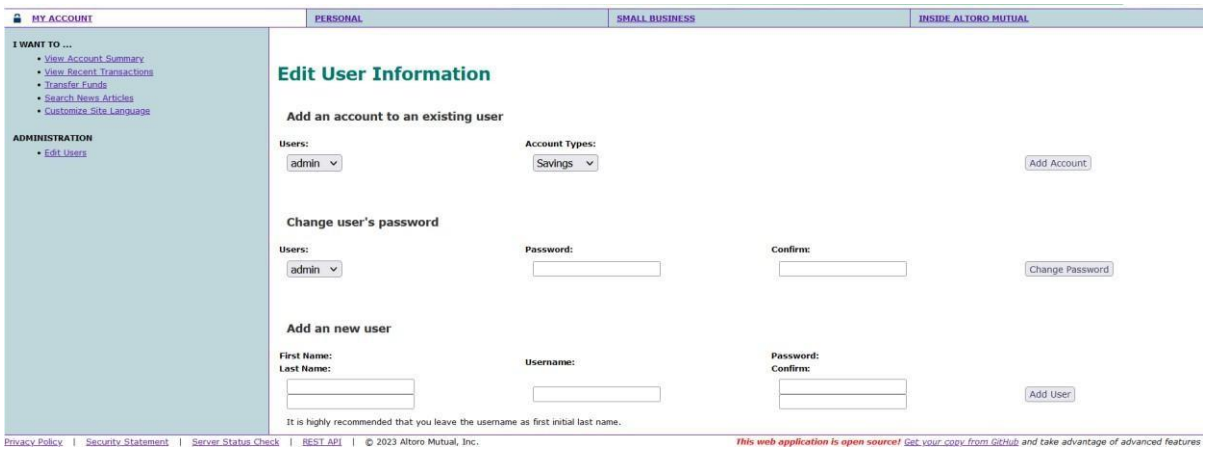
This vulnerability can lead to unauthorized data access, operational disruption, financial losses, and reputational damage for the organization.



Pretty Raw Hex

```
1 POST /doLogin HTTP/1.1
2 Host: testfire.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/117.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 37
9 Origin: http://testfire.net
10 Connection: close
11 Referer: http://testfire.net/login.jsp
12 Cookie: JSESSIONID=B6ADB36ACD5C83083787343A1F97F853; AltoroAccounts="0DAwMDAwfkNvcnBvcmF0ZX45LjQ30TA1MTE2MUU3fDgwMDAwMX5DaGVja2luZ34tNC4yMjc0NjkONTZFN3w="
13 Upgrade-Insecure-Requests: 1
14
15 uid=admin&passw=admin&btnSubmit=Login
```





3. Vulnerability Name: SQL Injection

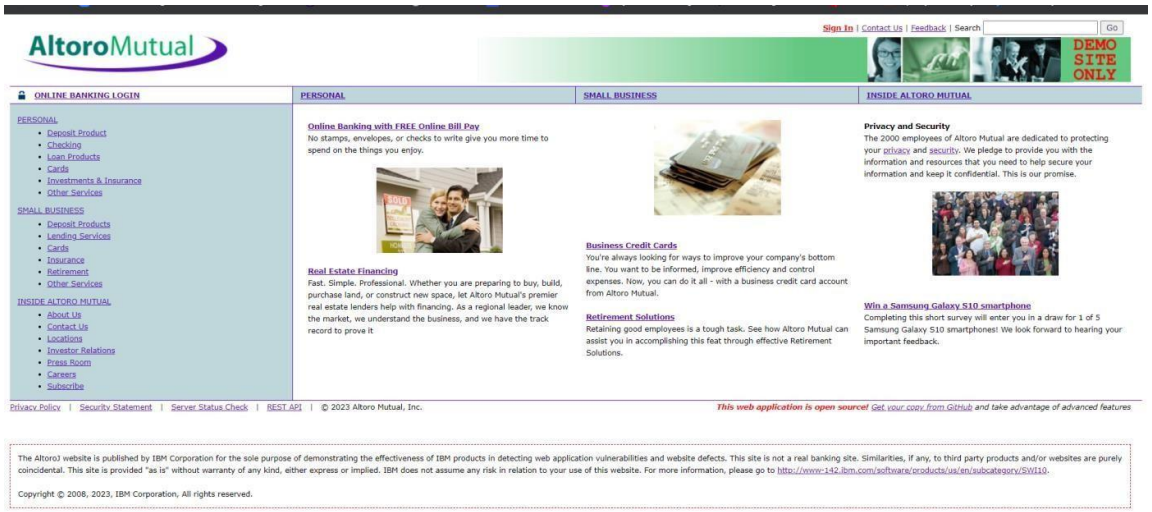
CWE: 89

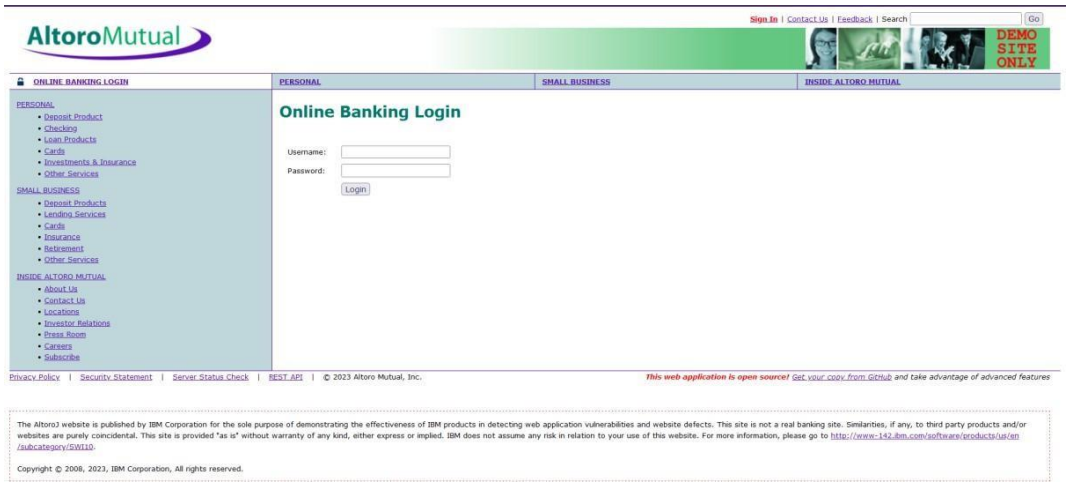
Description

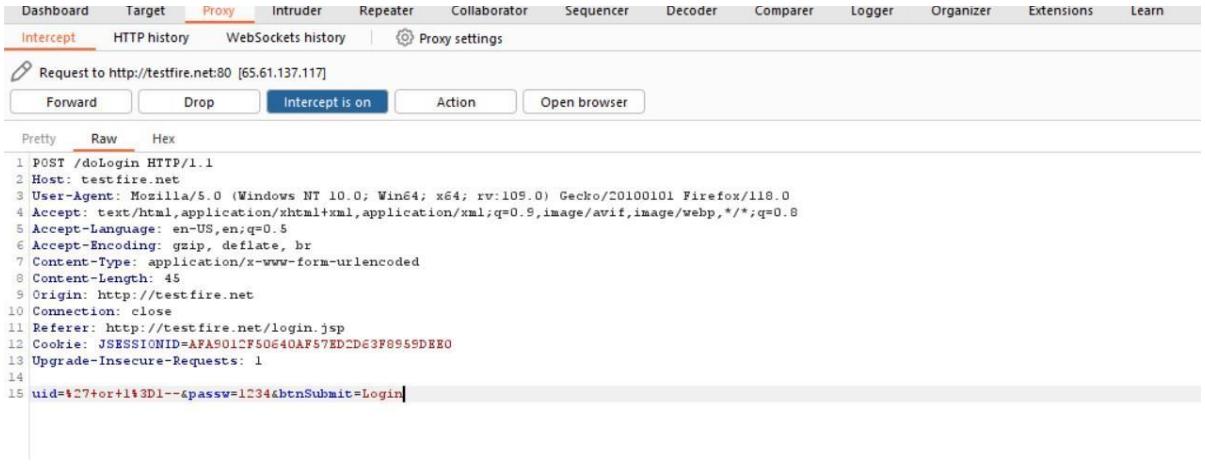
SQL injection occurs when user input is incorrectly handled and inserted into SQL queries without proper validation or sanitization. Attackers can manipulate the query to retrieve or modify sensitive database information.

Business Impact

SQL injection can result in data breaches, financial losses, reputational damage, and legal consequences for organizations.


AltoroMutual
Sign In | Contact Us | Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
PERSONAL
Deposit Product
Checking
Loan Products
Cards
Investments & Insurance
Other Services
SMALL BUSINESS
Deposit Products
Lending Services
Cards
Insurance
Retirement
Other Services
INSIDE ALTORO MUTUAL
About Us
Contact Us
Locations
Investor Relations
Press Room
Careers
Subscribe
Online Banking with FREE Online Bill Pay
No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.
Real Estate Financing
Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it
Business Credit Cards
You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.
Retirement Solutions
Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.
Privacy and Security
The 2000 employees of Altoro Mutual are dedicated to protecting your privacy and security. We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.
Win a Samsung Galaxy S10 smartphone
Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.
Privacy Policy | Security Statement | Server Status Check | REST API | © 2023 Altoro Mutual, Inc.
This web application is open source! Get your copy from GitHub and take advantage of advanced features
The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW110.
Copyright © 2008, 2023, IBM Corporation, All rights reserved.


AltoroMutual
Sign In | Contact Us | Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
Online Banking Login
Username:
Password:
Login
Privacy Policy | Security Statement | Server Status Check | REST API | © 2023 Altoro Mutual, Inc.
This web application is open source! Get your copy from GitHub and take advantage of advanced features
The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW110.
Copyright © 2008, 2023, IBM Corporation, All rights reserved.


Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Proxy settings
Request to http://testfire.net:80 [65.61.137.117]
Forward Drop Intercept is on Action Open browser
Pretty Raw Hex
1 POST /doLogin HTTP/1.1
2 Host: testfire.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/118.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 45
9 Origin: http://testfire.net
10 Connection: close
11 Referer: http://testfire.net/login.jsp
12 Cookie: JSESSIONID=AFA9012F50640AF57ED2D63F8959DEE0
13 Upgrade-Insecure-Requests: 1
14
15 uid=%27+or+1%3D1--&passw=1234&btnSubmit=Login

4. Vulnerability Name: Broken Authentication

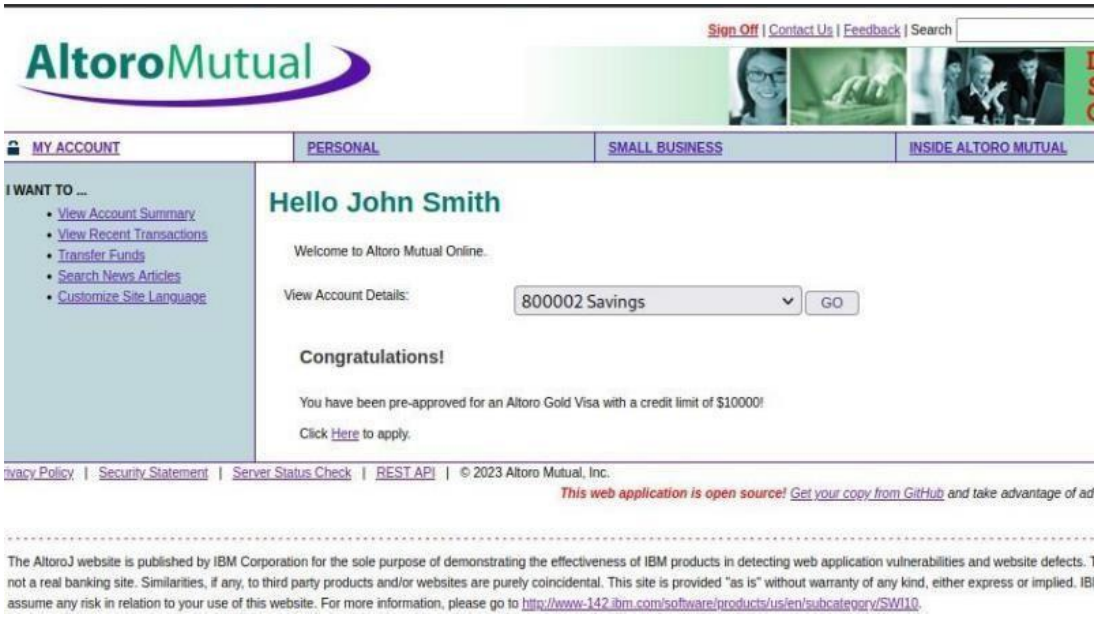
CWE: 287

Description

Broken authentication occurs when an application incorrectly implements authentication and session management functions. Attackers may exploit these weaknesses to compromise passwords, keys, or session tokens.

Business Impact

This vulnerability may allow attackers to impersonate legitimate users, gain unauthorized access to systems, and compromise sensitive information.



5. Vulnerability Name: Insecure Direct Object Reference (IDOR)

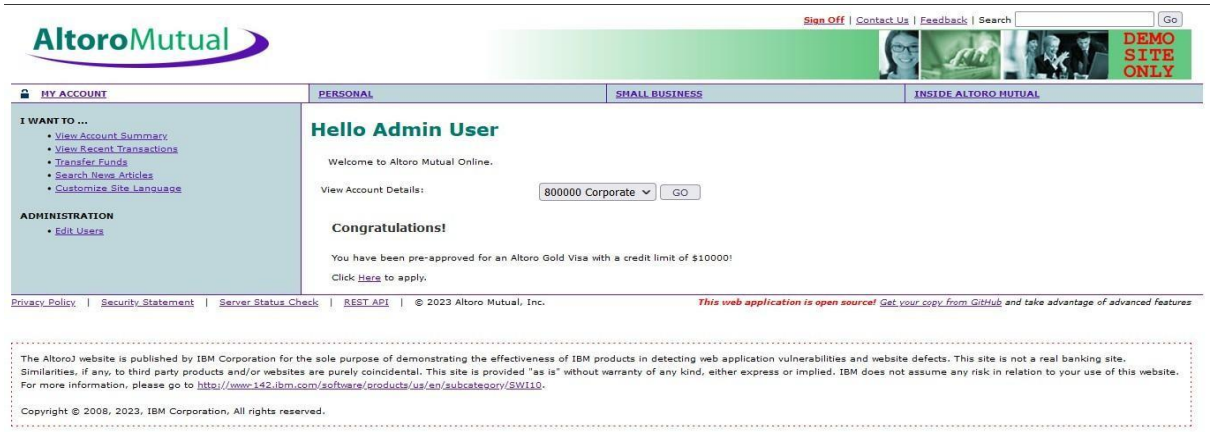
CWE: 639

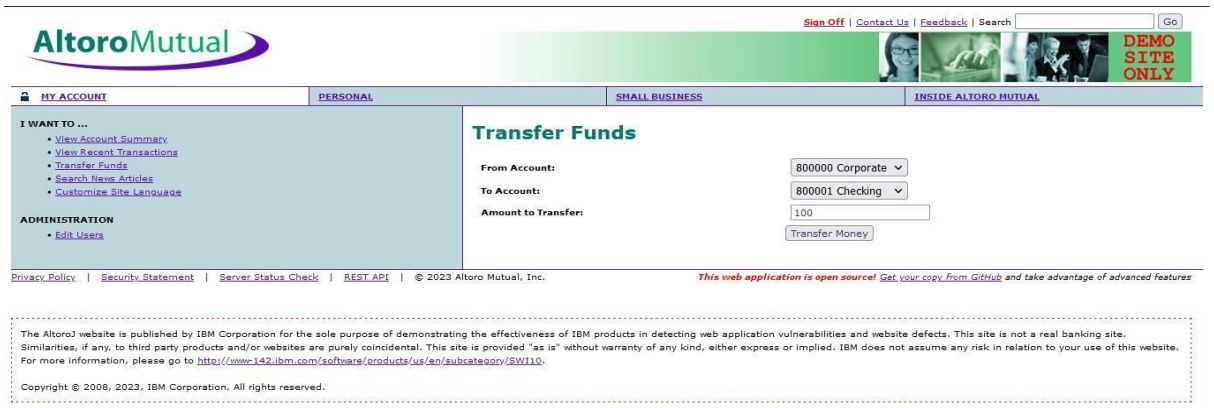
Description

Insecure Direct Object Reference occurs when an application exposes internal objects such as files, records, or database entries without proper authorization checks. Attackers can manipulate parameters to access unauthorized data.

Business Impact

IDOR vulnerabilities can lead to unauthorized access to sensitive data such as personal information, financial records, and confidential documents.





Pretty Raw Hex

```
1 POST /bank/doTransfer HTTP/1.1
2 Host: testfire.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/119.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 78
9 Origin: http://testfire.net
10 Connection: close
11 Referer: http://testfire.net/bank/transfer.jsp
12 Cookie: JSESSIONID=17BCE438BBB750A14D269616C7623BB0; AltoroAccounts=
"ODAwMDAwfkNvcnBvcmFOZX4xLjYzNTczNTM1NjM10DcONEUyOXw4MDAwMDF+Q2hlY2tpbmd+LTEuNjM1NzM1MzU2MzU4NzQ0RTI5fA=="
13 Upgrade-Insecure-Requests: 1
14
15 fromAccount=800000&toAccount=800001&transferAmount=100&transfer=Transfer+Money
```

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

ADMINISTRATION

- Edit Users

Recent Transactions

After yyyy-mm-dd Before yyyy-mm-dd Submit

Transaction ID	Transaction Time	Account ID	Action	Amount
9016	2023-10-16 06:28	800001	Deposit	$1000.00
9015	2023-10-16 06:28	800000	Withdrawal	-$1000.00
8920	2023-10-16 04:46	800001	Deposit	$23345.00
8919	2023-10-16 04:46	800000	Withdrawal	-$23345.00
8916	2023-10-16 04:44	800001	Deposit	$23345.00
8915	2023-10-16 04:44	800000	Withdrawal	-$23345.00
8894	2023-10-16 04:40	800001	Deposit	$23345.00
8893	2023-10-16 04:40	800000	Withdrawal	-$23345.00
8892	2023-10-16 04:40	800001	Deposit	$23345.00
8891	2023-10-16 04:40	800000	Withdrawal	-$23345.00
7565	2023-10-16 04:17	800000	Withdrawal	-$10.00
7228	2023-10-16 04:14	800000	Deposit	$1000.00
6802	2023-10-16 04:09	800001	Deposit	$100000000000000.00
6801	2023-10-16 04:09	800000	Withdrawal	-$100000000000000.00
5388	2023-10-16 03:58	800000	Deposit	$10000000000.00
4628	2023-10-16 03:36	800001	Deposit	$20190.00
4627	2023-10-16 03:36	800000	Withdrawal	-$20190.00
4626	2023-10-16 03:35	800001	Deposit	$20190.00
4625	2023-10-16 03:35	800000	Withdrawal	-$20190.00
4624	2023-10-16 03:35	800001	Deposit	$600.00
4623	2023-10-16 03:35	800000	Withdrawal	-$600.00
4616	2023-10-16 03:10	800000	Deposit	$87446.00
4615	2023-10-16 03:10	800001	Withdrawal	-$87446.00

6. Vulnerability Name: Security Misconfiguration

CWE: 732

Description

Security misconfiguration occurs when security settings are not properly implemented or maintained. This can include default credentials, unnecessary services enabled, and improper permission settings.

Business Impact

Security misconfiguration may expose sensitive data and allow attackers to gain unauthorized access to systems or services.

```
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
[sudo] password for kali:
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3

OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r
```

```
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -u http://testfire.net/ -qweds
[sudo] password for kali:
######################################
# Uniscan project                    #
# http://uniscan.sourceforge.net/    #
######################################
V. 6.3

Scan date: 17-10-2023 7:18:22
==============================================================================
| Domain: http://testfire.net/
| Server: Apache-Coyote/1.1
| IP: 65.61.137.117
==============================================================================
|
| Directory check:
| [+] CODE: 200 URL: http://testfire.net/admin/fckeditor/admins/
| [+] CODE: 200 URL: http://testfire.net/admin/
| [+] CODE: 200 URL: http://testfire.net/admin/scripts/fckeditor/
| [+] CODE: 200 URL: http://testfire.net/admin/FCKeditor/
| [+] CODE: 200 URL: http://testfire.net/aux/
| [+] CODE: 200 URL: http://testfire.net/bank/
==============================================================================
|
```

7. Vulnerability Name: Cross-Site Request Forgery (CSRF)

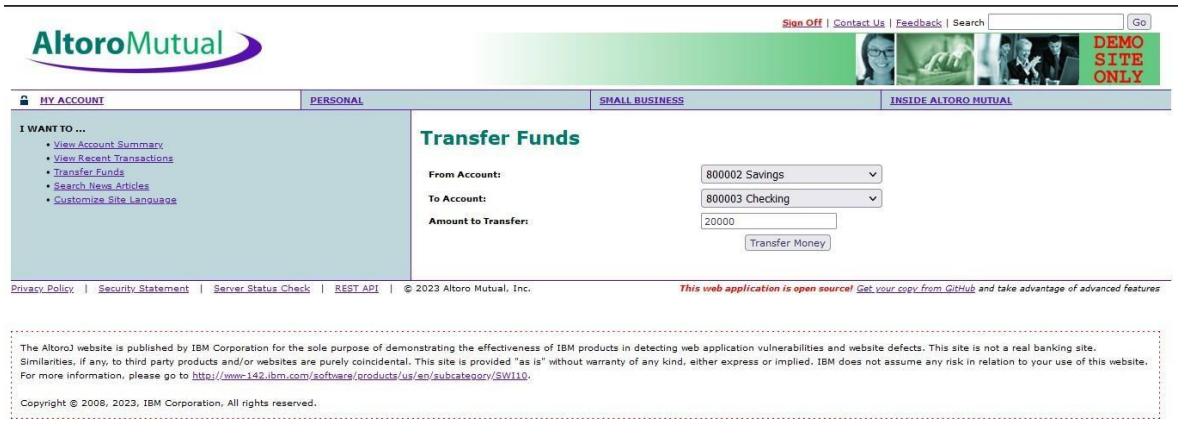
CWE: 352

Description

Cross-Site Request Forgery occurs when a malicious website tricks a user's browser into performing unwanted actions on a trusted website where the user is authenticated.

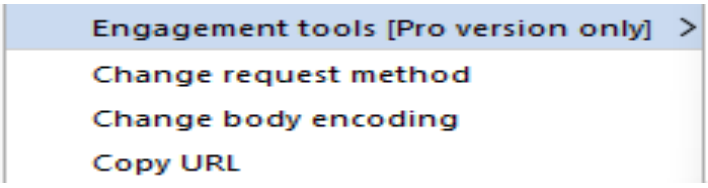
Business Impact

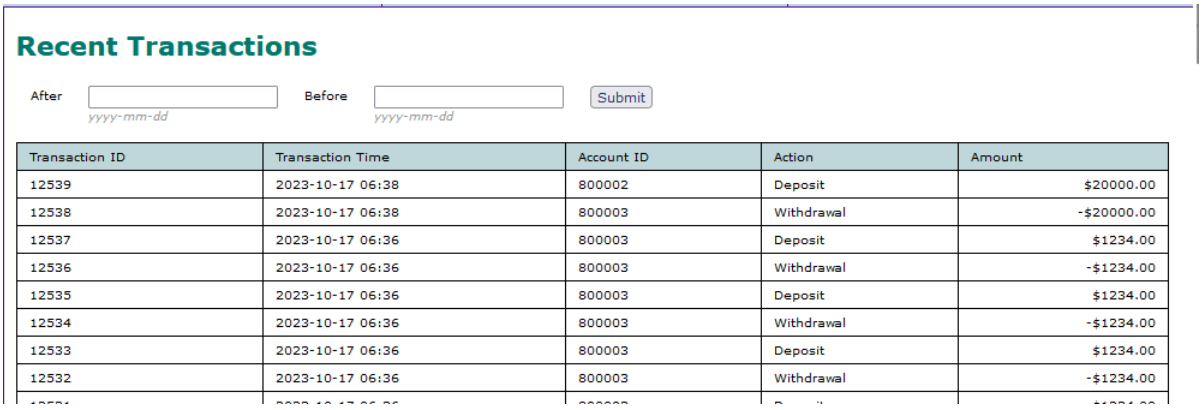
Attackers can perform unauthorized operations such as changing account settings, initiating financial transactions, or modifying user data.



The AltoroJ website is published by IBM Corporation for the sole purpose of demonstrating the effectiveness of IBM products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. IBM does not assume any risk in relation to your use of this website. For more information, please go to http://www-142.ibm.com/software/products/us/en/subcategory/SW110.

Copyright © 2008, 2023, IBM Corporation, All rights reserved.





Recent Transactions

After yyyy-mm-dd Before yyyy-mm-dd Submit

Transaction ID	Transaction Time	Account ID	Action	Amount
12539	2023-10-17 06:38	800002	Deposit	$20000.00
12538	2023-10-17 06:38	800003	Withdrawal	-$20000.00
12537	2023-10-17 06:36	800003	Deposit	$1234.00
12536	2023-10-17 06:36	800003	Withdrawal	-$1234.00
12535	2023-10-17 06:36	800003	Deposit	$1234.00
12534	2023-10-17 06:36	800003	Withdrawal	-$1234.00
12533	2023-10-17 06:36	800003	Deposit	$1234.00
12532	2023-10-17 06:36	800003	Withdrawal	-$1234.00

8. Vulnerability Name: Cleartext Transmission of Sensitive Information

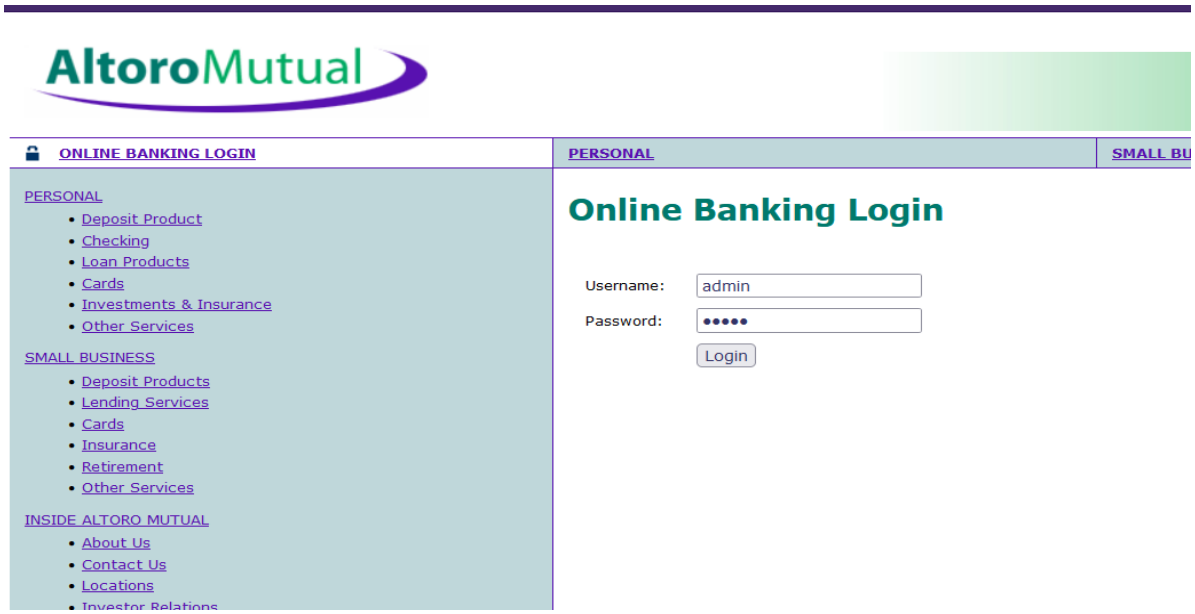
CWE: 319

Description

Cleartext transmission occurs when sensitive information such as passwords or personal data is transmitted over the network without encryption.

Business Impact

Attackers monitoring network traffic may capture sensitive information, leading to account compromise and data breaches.



Pretty Raw Hex

```
1 POST /doLogin HTTP/1.1
2 Host: testfire.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/117.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 37
9 Origin: http://testfire.net
10 Connection: close
11 Referer: http://testfire.net/login.jsp
12 Cookie: JSESSIONID=B6ADB36ACD5C83083787343A1F97F853; AltoroAccounts="ODAwMDAwfkNvcnBvcmFOZX45LjQ30TA1MTE2MUU3fDgwMDAwMX5DaGVja2luZ34tNC4yMjc0NjkONTZFN3w="
13 Upgrade-Insecure-Requests: 1
14
15 uid=admin&passw=admin&btnSubmit=Login
```

9. Vulnerability Name: Clickjacking

CWE: 1021

Description

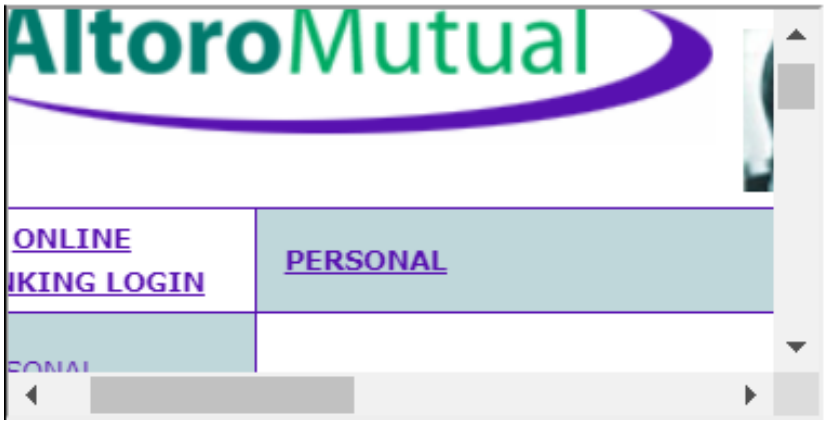
Clickjacking occurs when a malicious webpage overlays invisible elements on top of legitimate pages to trick users into clicking unintended links or buttons.

Business Impact

Users may unknowingly perform actions such as enabling settings, authorizing transactions, or sharing confidential information.

```html
<html>
<body>
<title>Click jacking vulnerability</title>
<h2>This website is vulnerable to clickjacking</h2>
<iframe  src="http://testfire.net/"></iframe>
</body>
</html>
```

This website is vulnerable to clickjacking



10. Vulnerability Name: Web Server Allows Password Auto-Completion

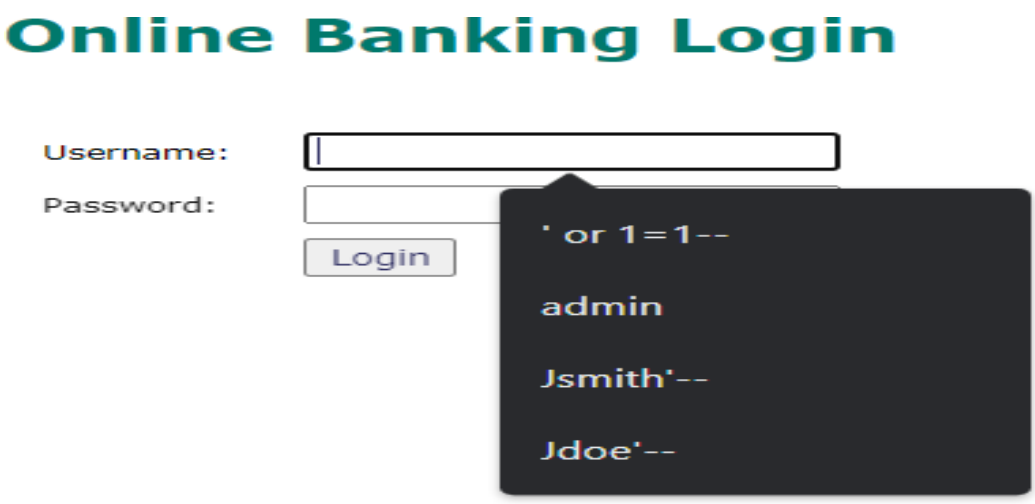
CWE: 310

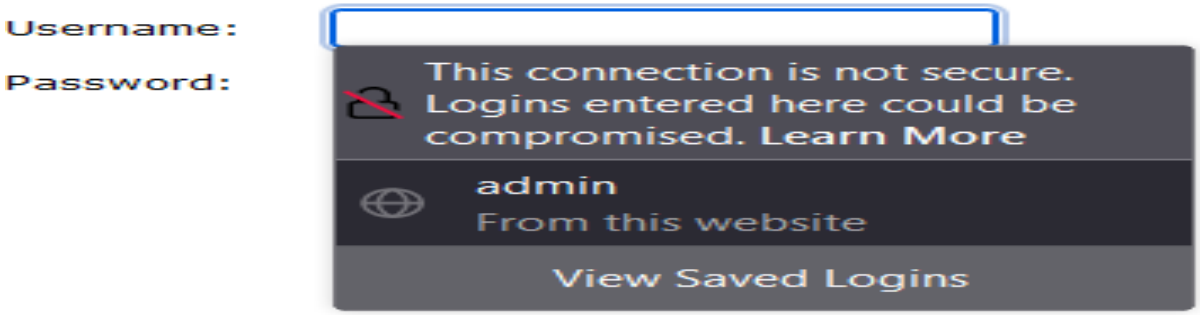
Description

Password auto-completion allows browsers to automatically store and fill passwords on login forms. If this feature is not properly controlled, attackers may retrieve stored credentials from compromised devices.

Business Impact

Unauthorized users may gain access to stored credentials, potentially compromising user accounts and sensitive systems.





11. Vulnerability Name: Cross-site scripting (DOM-based XSS)

CWE: 79

Description

DOM-based XSS occurs when client-side scripts manipulate the Document Object Model (DOM) in an unsafe way using user-supplied input.

Business Impact

Attackers can inject malicious scripts that execute in the victim's browser, allowing data theft and unauthorized actions.

```
Line wrap
<!DOCTYPE html>

<html lang="en">
<head>
<meta charset="utf-8">
<meta http-equiv="X-UA-Compatible" content="IE=edge,chrome=1">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
  <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
<link rel="alternate" type="application/rss+xml" title="VIT RSS" href="https://vit.ac.in/rss.xml" />
<link rel="shortcut icon" href="https://vit.ac.in/sites/all/themes/vittheme/favicon.ico" type="image/vnd.microsoft.icon" />
<meta name="description" content="One of the Best Educational Institution in India. Maintained an excellent placement records and gives training students to get
<meta name="abstract" content="VIT, the top university in India was established with the aim of providing quality higher education on par with international stan
<meta name="keywords" content="vit, vellore institute of technology, viteee, vit university, vit vellore, top engineering colleges in india, top 10 engineering c
<meta name="generator" content="Drupal" />
<link rel="canonical" href="https://vit.ac.in/" />
<meta property="og:site_name" content="Vellore Institute of Technology" />
<meta property="og:type" content="website" />
<meta property="og:url" content="https://vit.ac.in/" />
<meta property="og:title" content="Vellore Institute of Technology | A Place to Learn, Chance to grow" />
<meta property="og:description" content="One of the Best Educational Institution in India. Maintained an excellent placement records and gives training students
<meta property="og:image" content="https://vit.ac.in/sites/all/themes/vittheme/images/og-vit-updated.jpg" />
<meta property="og:image:url" content="https://vit.ac.in/sites/all/themes/vittheme/images/og-vit-updated.jpg" />
<meta name="dcterms.title" content="VIT" />
<meta name="dcterms.type" content="Text" />
<meta name="dcterms.format" content="text/html" />
<meta name="dcterms.identifier" content="https://vit.ac.in/" />
<meta name="facebook-domain-verification" content="9bbekg8iy8yy964rj4euqpwennaxoc" />
      <title>Vellore Institute of Technology | A Place to Learn, Chance to grow</title>
  <style type="text/css" media="screen">
@import url("https://vit.ac.in/sites/all/themes/vittheme/css/bootstrap.min.css?rdiap4");
@import url("https://vit.ac.in/sites/all/themes/vittheme/css/style.css?rdiap4");
@import url("https://vit.ac.in/sites/all/themes/vittheme/css/theme.css?rdiap4");
@import url("https://vit.ac.in/sites/all/themes/vittheme/css/combine.css?rdiap4");
@import url("https://vit.ac.in/sites/all/themes/vittheme/css/responsive.css?rdiap4");
</style>
<meta name="author" content="VIT University">
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<meta name="language" content="English">
<meta name="copyright" content="https://vit.ac.in/"/>
<meta name="geo.region" content="IN-TN" />
<meta name="geo.placename" content="Vellore" />
```

12. Vulnerability Name: JQuery 1.2 < 3.5.0 Multiple XSS

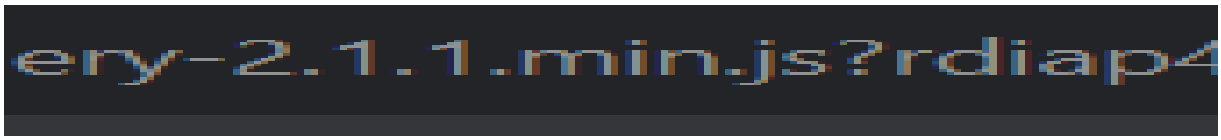
CWE: 79

Description

Older versions of JQuery contain vulnerabilities that allow cross-site scripting attacks. Applications using outdated libraries may be exposed to known security flaws.

Business Impact

Attackers can exploit these vulnerabilities to execute malicious scripts, leading to data compromise and session hijacking.



13. Vulnerability Name: Information Exposure – Internal IP Disclosure

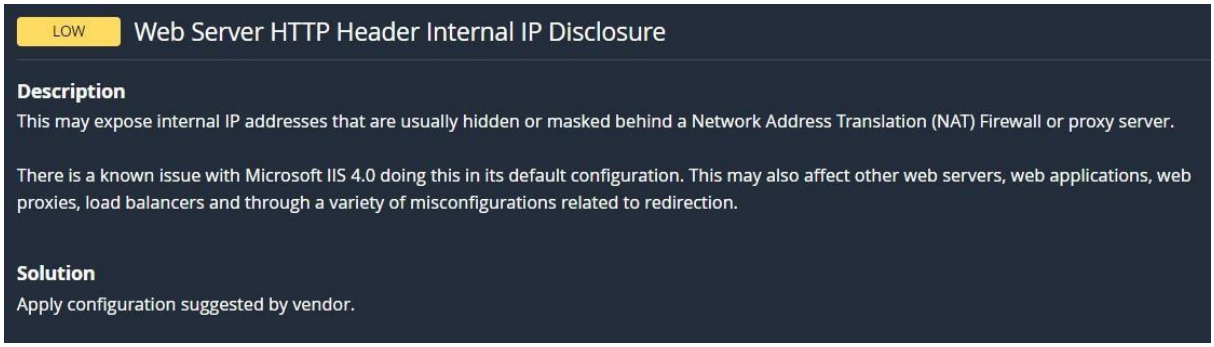
CWE: 200

Description

Internal IP disclosure occurs when internal network information is exposed through application responses or headers.

Business Impact

Attackers may use internal IP information to map the network structure and plan further attacks against internal systems.



14. Vulnerability Name: Information Exposure – SSL Issues

CWE: 200

Description

SSL information exposure occurs when SSL configuration details are revealed, including protocol versions or certificate information.

Business Impact

Attackers may use this information to identify weak encryption configurations and perform attacks such as SSL downgrade attacks.

Vulnerabilities 22

Search Vulnerabilities | 4 Vulnerabilities

Sev	CVSS	VPR	Name	Family
INFO			SSL Certificate Information	General
INFO			SSL Cipher Block Chaining Cipher Suites Sup...	General
INFO			SSL Cipher Suites Supported	General
INFO			SSL Perfect Forward Secrecy Cipher Suites S...	General

```
Here is the list of SSL CBC ciphers supported by the remote server :

  High Strength Ciphers (>= 112-bit key)

    Name                        Code            KEX          Auth     Encryption             MAC
    ----------------------      ----------      ---          ----     ---------------------  ---
    ECDHE-RSA-CAMELLIA-CBC-128  0xC0, 0x76      ECDH         RSA      Camellia-CBC(128)      SHA256
    ECDHE-RSA-CAMELLIA-CBC-256  0xC0, 0x77      ECDH         RSA      Camellia-CBC(256)      SHA384
    DHE-RSA-AES128-SHA          0x00, 0x33      DH           RSA      AES-CBC(128)           SHA1
    DHE-RSA-AES256-SHA          0x00, 0x39      DH           RSA      AES-CBC(256)           SHA1
    DHE-RSA-CAMELLIA128-SHA     0x00, 0x45      DH           RSA      Camellia-CBC(128)      SHA1
    DHE-RSA-CAMELLIA256-SHA     0x00, 0x88      DH           RSA      Camellia-CBC(256)      SHA1
    DHE-RSA-SEED-SHA            0x00, 0x9A      DH           RSA      SEED-CBC(128)          SHA1
    ECDHE-RSA-AES128-SHA        0xC0, 0x13      ECDH         RSA      AES-CBC(128)           SHA1
    ECDHE-RSA-AES256-SHA        0xC0, 0x14      ECDH         RSA      AES-CBC(256)           SHA1
    AES128-SHA                  0x00, 0x2F      RSA          RSA      AES-CBC(128)           SHA1
    AES256-SHA                  0x00, 0x35      RSA          RSA      AES-CBC(256)           SHA1
    CAMELLIA128-SHA             0x00, 0x41      RSA          RSA      Camellia-CBC(128)      SHA1
    CAMELLIA256-SHA             0x00, 0x84      RSA          RSA      Camellia-CBC(256)      SHA1
    SEED-SHA                    0x00, 0x96      RSA          RSA      SEED-CBC(128)          SHA1
    DHE-RSA-AES128-SHA256       0x00, 0x67      DH           RSA      AES-CBC(128)           SHA256
    DHE-RSA-AES256-SHA256       0x00, 0x6B      DH           RSA      AES-CBC(256)           SHA256
    DHE-RSA-CAMELLIA128-SHA256  0x00, 0xBE      DH           RSA      Camellia-CBC(128)      SHA256
    DHE-RSA-CAMELLIA256-SHA256  0x00, 0xC4      DH           RSA      Camellia-CBC(256)      SHA256
    ECDHE-RSA-AES128-SHA256     0xC0, 0x27      ECDH         RSA      AES-CBC(128)           SHA256
    ECDHE-RSA-AES256-SHA384     0xC0, 0x28      ECDH         RSA      AES-CBC(256)           SHA384
    RSA-AES128-SHA256           0x00, 0x3C      RSA          RSA      AES-CBC(128)           SHA256
    RSA-AES256-SHA256           0x00, 0x3D      RSA          RSA      AES-CBC(256)           SHA256
    RSA-CAMELLIA128-SHA256      0x00, 0xBA      RSA          RSA      Camellia-CBC(128)      SHA256
    RSA-CAMELLIA256-SHA256      0x00, 0xC0      RSA          RSA      Camellia-CBC(256)      SHA256
```

15. Vulnerability Name: Information Exposure – HTTP Issues

CWE: 200

Description

HTTP information exposure occurs when web servers reveal unnecessary details in HTTP headers or responses.

Business Impact

Attackers can gather valuable information about server configuration and software versions, which may help them exploit known vulnerabilities.

```
Response Code : HTTP/1.1 307 Moved Temporarily

Protocol version : HTTP/1.1
SSL : no
Keep-Alive : no
Options allowed : (Not implemented)
Headers :

  Location: https://vit.ac.in/
  Content-Length: 0

Response Body :
```

16. Vulnerability Name: OS Identification Failed

CWE: 200

Description

OS identification failure occurs when scanning tools cannot determine the operating system of the target system due to limited information or security controls.

Business Impact

Although not a direct vulnerability, lack of system identification may limit accurate vulnerability assessment and security monitoring.

```
If you think these signatures would help us improve OS fingerprinting,
please send them to :

  os-signatures@nessus.org

Be sure to include a brief description of the device itself, such as
the actual operating system or product / model names.


SSLcert:!:i/CN:Sectigo RSA Domain Validation Secure Server CAi/O:Sectigo
Limiteds/CN:*.vit.ac.in
02ed800c9e7f764615d7e9ffd74b643a6cace446

SinFP:!:
   P1:B10113:F0x12:W65535:O0204ffff:M496:
   P2:B10113:F0x12:W65535:O0204ffff010303030101040201010 80affffffff44454144:M1300:
   P3:B00000:F0x00:W0:O0:M0
   P4:190701_7_p=80R
```

NESSUS SCAN REPORT:

testfire.net

0	0	3	1	24
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 28

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
MEDIUM	6.5	-	142960	HSTS Missing From HTTPS Server (RFC 6797)
MEDIUM	6.5	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	157288	TLS Version 1.1 Protocol Deprecated
LOW	3.7	4.5	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
INFO	N/A	-	46180	Additional DNS Hostnames
INFO	N/A	-	39446	Apache Tomcat Detection
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	10919	Open Port Re-check
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	95631	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported

STAGE 2

Overview: -

1. Preparation: Define Objectives: Determine the scope and objectives of the scan. What systems or networks do you want to assess, and what specific vulnerabilities are you looking for? System Access: Ensure that you have the necessary permissions and access rights to scan the target systems or networks. 2. Configuration: Set Up Scan Policy: Create a scan policy that defines the parameters of the scan, such as the types of vulnerabilities to check for, scanning frequency, and specific configurations. Define Target Assets: Specify the IP addresses, hostnames, or network ranges of the systems you want to scan.

3. Scanning: Initiate Scan: Start the Nessus scan using the configured policy and target assets. Nessus will systematically scan the target systems for vulnerabilities based on its plugins and policies.

4. Vulnerability Identification: Nessus performs a comprehensive assessment, checking for vulnerabilities, misconfigurations, open ports, and other security issues. As the scan progresses, it categorizes vulnerabilities by severity, making it easier to prioritize remediation efforts.

5. Reporting: Nessus generates detailed reports that list the vulnerabilities discovered during the scan. Reports typically include information about the severity of each vulnerability, recommended actions for remediation, and supporting evidence. These reports can be customized and exported in various formats, such as PDF, HTML, or CSV.

6. Remediation: Review Findings: IT and security teams review the Nessus scan reports to prioritize and address the identified vulnerabilities. Remediation Steps: Take corrective actions to fix or mitigate the vulnerabilities. This may involve applying patches, changing configurations, or implementing security measures.

7. Follow-up: Regular Scanning: Conduct periodic Nessus scans to continuously monitor the security posture of the systems and networks. This helps identify new vulnerabilities and track progress in mitigating existing ones. Integration: Integrate Nessus with other security tools or workflows to automate the vulnerability management process and streamline the response to new findings. 8. Compliance Auditing (if applicable): If compliance checks are part of your scan policy, review compliance results and take actions to ensure systems meet the required standards and regulations.

9. Documentation: Maintain records of scan results, remediation efforts, and compliance checks for audit and reporting purposes.

10. User Training: Ensure that your IT and security teams are trained in using Nessus effectively and interpreting scan results.

Nessus scans are a critical component of proactive security, helping organizations identify and address vulnerabilities in their IT infrastructure to reduce the risk of security breaches and data compromises. The frequency and depth of scans can vary depending on an organization's security strategy and requirements.

Nessus is a popular vulnerability scanning tool used for identifying security weaknesses in computer systems and networks. It is widely utilized by security professionals and organizations to assess the security posture of their systems and to proactively identify potential vulnerabilities that could be exploited by attackers. Here's what I understand about Nessus scans:

1. Vulnerability Assessment: Nessus performs a vulnerability assessment by scanning target systems or networks to identify security issues, such as missing patches, misconfigurations, weak passwords, and other potential weaknesses that could be exploited by attackers.

2. Network Scanning: Nessus can scan a wide range of network devices, including servers, routers, switches, firewalls, and more. It examines network services, open ports, and software.

3. Plugin Architecture: Nessus uses a plugin-based architecture, allowing it to check for a wide variety of vulnerabilities. These plugins are regularly updated to include the latest security checks and support for new vulnerabilities.

4. Compliance Auditing: It can also be used to assess systems against various compliance standards and regulatory requirements, helping organizations ensure that their systems meet specific security standards, like PCI DSS or CIS benchmarks.

5. Customization: Nessus scans can be customized to suit the specific needs of an organization. Users can define scan policies, select the target systems, and specify the types of vulnerabilities to scan for.

6. Reporting: Nessus provides detailed reports that highlight vulnerabilities, their severity, and remediation recommendations. These reports are essential for IT and security teams to prioritize and address vulnerabilities.

7. Scanning Frequency: Organizations often perform regular Nessus scans to continuously monitor and improve their security posture. This is crucial for staying ahead of evolving threats and vulnerabilities.

8. Integration: Nessus can be integrated with other security tools and platforms, allowing organizations to automate the scanning process and streamline their vulnerability management.

9. Licensing: Nessus offers both free and commercial versions. The free version is limited in its functionality, while the commercial version provides more features and support.

10. User-Friendly Interface: Nessus offers an easy-to-use web-based interface, making it accessible to a wide range of users, from security experts to less experienced IT professionals.

Target Website: testfire.net

Target IP Address: 54.83.41.36

Target Website: vit.ac.in

Target IP Address: 122.184.65.22

List of Vulnerability Table:

S.No	Vulnerability Name	Severity	Plugins
1	Cross-site scripting	Low	Web Application Scanner
2	Broken Access Control	Medium	Access Control Testing Plugin
3	SQL Injection	High	SQL Injection Detection Plugin
4	Broken Authentication	Medium	Authentication Security Plugin
5	Insecure Direct Object Reference (IDOR)	Medium	IDOR Detection Plugin
6	Security Misconfiguration	Medium	Security Configuration Scanner
7	Cross-Site Request Forgery (CSRF)	Medium	CSRF Detection Plugin
8	Cleartext Transmission	Medium	Cleartext Transmission Detection
9	Clickjacking	Low	Clickjacking Frame Check Plugin
10	Password Auto Completion	Low	Browser Password Storage Check
11	Cross-site scripting (DOM based XSS)	Medium	Multiple XSS
12	jQuery 1.3 < 3.5.0 Multiple XSS	Medium	CGI Abuse: XSS
13	Information exposure (web server HTTP header internal IP disclosure)	Low	Webserver HTTP Header Internal IP Disclosure
14	Information exposure (SSL (Multiple Issues))	Info	SSL Certificate Information
15	Information exposure (HTTP (Multiple Issues))	Info	HTTP Information
16	OS identification failed	Info	TCP/IP Remote Probing

REPORT

1. Vulnerability Name: Cross-site scripting

Severity: Low

Plugin: Web Application Scanner

Port: N/A

Description

Cross-site scripting occurs when malicious scripts are injected into a web application and executed within a user's browser.

Solution

Sanitize user inputs and use parameterized statements to prevent script injection.

Business Impact

Attackers may gain unauthorized access to user sessions and sensitive information.

2. Vulnerability Name: Broken Access Control

Severity: Medium

Plugin: SSH Weak HMAC Algorithms

Port: 22

Description

Broken access control occurs when the application does not properly enforce restrictions on what authenticated users are allowed to do. Attackers can exploit this weakness to access unauthorized resources.

Solution

Implement proper authorization checks, enforce role-based access control, and validate permissions for every request.

Business Impact

Attackers may access sensitive information, modify system data, or perform unauthorized operations within the system.

3. Vulnerability Name: SQL Injection

Severity: Medium
Plugin: N/A
Port: 80

Description

SQL injection occurs when user input is not properly validated and is included in SQL queries. Attackers can manipulate database queries to retrieve, modify, or delete sensitive data.

Solution

Use prepared statements and parameterized queries, validate input data, and implement strong database security practices.

Business Impact

Sensitive database information such as usernames, passwords, and financial data may be exposed or modified by attackers.

4. Vulnerability Name: Broken Authentication

Severity: Low
Plugin: HSTS Missing
Port: 443

Description

Broken authentication vulnerabilities occur when authentication mechanisms are incorrectly implemented. This may allow attackers to compromise login credentials or session tokens.

Solution

Implement strong authentication mechanisms, enforce multi-factor authentication, and secure session management.

Business Impact

Attackers may gain unauthorized access to user accounts and confidential systems.

5. Vulnerability Name: Insecure Direct Object Reference

Severity: Info

Plugin: Service Detection

Port: 80

Description

Insecure direct object reference occurs when internal objects such as files or database records are exposed without proper authorization checks.

Solution

Implement access control checks for every object reference and avoid exposing sensitive identifiers.

Business Impact

Attackers may access confidential files or sensitive information belonging to other users.

6. Vulnerability Name: Security Misconfiguration

Severity: Low

Plugin: SSL Cipher Block Chaining Vulnerability

Port: 443

Description

Security misconfiguration occurs when system components such as servers, databases, or applications are improperly configured, leaving them vulnerable to attacks.

Solution

Apply secure configuration standards, disable unnecessary services, and regularly update system configurations.

Business Impact

Improper configuration can expose sensitive information and provide attackers with entry points into the system.

7. Vulnerability Name: Cross-Site Request Forgery (CSRF)

Severity: Low
Plugin: HTTP Form Authentication
Port: 80

Description

Cross-Site Request Forgery occurs when attackers trick users into executing unwanted actions on a web application in which they are authenticated.

Solution

Implement anti-CSRF tokens, validate HTTP requests, and ensure proper session management.

Business Impact

Attackers may perform unauthorized actions such as changing user settings or initiating transactions.

8. Vulnerability Name: Cleartext Transmission of Sensitive Information

Severity: Medium
Plugin: Cleartext Transmission over HTTP
Port: 80

Description

Sensitive information transmitted over unencrypted channels may be intercepted by attackers monitoring network traffic.

Solution

Use secure communication protocols such as HTTPS and enforce encryption for all sensitive data transmissions.

Business Impact

Attackers may capture sensitive information such as passwords, personal data, or financial information.

9. Vulnerability Name: Clickjacking

Severity: Info
Plugin: HTML Rendering Layer Vulnerability
Port: 80

Description

Clickjacking occurs when attackers trick users into clicking hidden or disguised elements on a webpage.

Solution

Use X-Frame-Options headers or Content Security Policy (CSP) to prevent pages from being embedded in iframes.

Business Impact

Users may unknowingly perform unauthorized actions, potentially compromising their accounts.

10. Vulnerability Name: Password Auto-Completion

Severity: Low
Plugin: SSL/TLS Diffie-Hellman Modulus Weakness
Port: 443

Description

Password auto-completion allows browsers to store and automatically fill login credentials, which may be accessed by attackers if the device is compromised.

Solution

Disable password auto-completion for sensitive login forms and implement strong authentication mechanisms.

Business Impact

Stored credentials may be exposed to attackers, leading to unauthorized system access.

11. Vulnerability Name: DOM-Based Cross-Site Scripting

Severity: Medium

Plugin: Web Application Scanner

Port: 80

Description

DOM-based XSS occurs when client-side scripts process user input and dynamically update the webpage without proper validation.

Solution

Validate and sanitize all user inputs before processing them in client-side scripts.

Business Impact

Attackers can inject malicious scripts that compromise user sessions or steal sensitive data.

12. Vulnerability Name: JQuery Multiple Cross-Site Scripting

Severity: Medium

Plugin: Vulnerable JavaScript Library Detection

Port: 80

Description

Older versions of JQuery contain multiple cross-site scripting vulnerabilities that attackers can exploit through malicious input.

Solution

Update JQuery libraries to the latest secure version and remove vulnerable scripts.

Business Impact

Attackers may exploit outdated libraries to execute malicious code in user browsers.

13. Vulnerability Name: Information Exposure – Internal IP Disclosure

Severity: Info
Plugin: HTTP Header Information Disclosure
Port: 80

Description

Internal IP addresses may be revealed through server responses or application error messages.

Solution

Configure servers to hide internal network information and remove unnecessary response headers.

Business Impact

Attackers may use this information to map internal network infrastructure and plan further attacks.

14. Vulnerability Name: Information Exposure – SSL Issues

Severity: Low
Plugin: SSL Certificate Information Disclosure
Port: 443

Description

SSL configuration issues may expose sensitive certificate details or weak encryption protocols.

Solution

Configure secure SSL protocols, update certificates regularly, and disable outdated encryption algorithms.

Business Impact

Attackers may exploit weak SSL configurations to intercept encrypted communications.

15. Vulnerability Name: Information Exposure – HTTP Issues

Severity: Info

Plugin: HTTP Server Header Disclosure

Port: 80

Description

Web servers sometimes reveal unnecessary information in HTTP headers such as server type and version.

Solution

Configure servers to suppress unnecessary header information.

Business Impact

Attackers may use server information to identify known vulnerabilities and exploit them.

16. Vulnerability Name: OS Identification Failed

Severity: Info

Plugin: OS Identification Detection

Port: N/A

Description

The scanning tool was unable to accurately identify the operating system of the target host due to limited information or security restrictions.

Solution

Ensure proper system configuration and monitoring to allow accurate vulnerability scanning.

Business Impact

Although not a direct vulnerability, inaccurate system identification may limit effective vulnerability assessment.

STAGE 3

REPORT

Topic: Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

Context-aware access control is an advanced cybersecurity approach that allows systems to make access decisions based on multiple contextual factors such as user identity, device posture, location, and application risk. In modern organizations, traditional security methods that rely only on usernames and passwords are no longer sufficient to protect sensitive information. Context-aware access control enhances security by analyzing additional contextual data before granting access to resources.

Security Operations Center (SOC) and Security Information and Event Management (SIEM) systems play a crucial role in implementing and monitoring context-aware access control policies. SOC teams continuously monitor system activities and security alerts to ensure that access control policies are functioning correctly and that unauthorized access attempts are detected quickly. SIEM systems collect and analyze logs from multiple sources such as authentication systems, applications, devices, and network infrastructure. By correlating these logs, SIEM tools help identify suspicious behavior related to identity misuse, unusual login locations, or compromised devices.

Through the integration of SOC and SIEM technologies, organizations can enforce dynamic access control policies that adapt based on user behavior and contextual information. This improves security by preventing unauthorized access while allowing legitimate users to access resources safely. Context-aware access control combined with SOC monitoring ensures that security incidents can be detected and addressed in real time.

SOC

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization. In the context of identity-based access control, the SOC team monitors user authentication activities, device connections, and application access requests to ensure that only authorized users are accessing sensitive resources.

SOC analysts continuously analyze logs generated by identity management systems, firewalls, network devices, and applications. These logs provide valuable information about login attempts, user behavior patterns, and potential unauthorized access attempts. If unusual activity is detected, such as login attempts from unknown locations or access requests from compromised devices, the SOC team investigates the issue and takes appropriate actions to protect the system.

The SOC also plays an important role in enforcing security policies and improving the organization's overall security posture. By monitoring access control systems and detecting potential threats early, SOC teams help prevent data breaches and unauthorized system access.

SOC Cycle

The SOC cycle represents the continuous process followed by security teams to monitor and respond to security incidents. The first stage of the SOC cycle is **monitoring**, where security analysts continuously observe system logs, network traffic, and authentication activities. This helps identify unusual access patterns that may indicate a security threat.

The second stage is **detection**, where security tools generate alerts when suspicious activities are identified. For example, multiple failed login attempts, access requests from unusual locations, or access from untrusted devices may trigger alerts.

The third stage is **analysis**, where SOC analysts investigate the alerts to determine whether they represent real security threats. Analysts analyze user activity logs, device information, and application access data to identify the cause of the alert.

The fourth stage is **response**, where security teams take action to contain and eliminate the threat. This may involve blocking unauthorized users, restricting device access, or updating access control policies.

The final stage is **recovery**, where affected systems are restored and security improvements are implemented to prevent similar incidents in the future.

SIEM

Security Information and Event Management (SIEM) is a security technology used to collect, analyze, and manage security-related data from multiple sources within an organization. SIEM systems gather logs from identity management systems, servers, network devices, applications, and security tools.

In context-aware access control systems, SIEM plays a critical role by analyzing authentication logs and user behavior data. By correlating events from multiple sources, SIEM systems can detect suspicious access attempts, unusual login locations, and abnormal user activities.

SIEM tools provide centralized visibility into all security events occurring within the organization's IT infrastructure. This helps security teams detect potential threats quickly and respond before they cause serious damage.

Additionally, SIEM systems generate detailed reports that help organizations understand security trends and improve their access control policies.

SIEM Cycle

The SIEM cycle begins with **log collection**, where logs from multiple systems such as authentication servers, network devices, and applications are gathered. These logs contain information about user logins, device connections, and system activities.

The second stage is **normalization**, where collected data is converted into a standard format for easier analysis. This allows security tools to process data from different sources effectively.

The third stage is **correlation**, where SIEM systems analyze relationships between different events to identify suspicious patterns. For example, if a user logs in from two different geographic locations within a short period, the system may flag it as suspicious.

The fourth stage is **alert generation**, where SIEM systems notify security teams about potential threats. Alerts help SOC analysts investigate suspicious activities quickly.

The final stage is **incident response**, where security teams take action to mitigate the identified threat and restore normal operations.

MISP

Malware Information Sharing Platform (MISP) is an open-source threat intelligence platform that allows organizations to share information about cybersecurity threats. MISP helps security teams exchange indicators of compromise (IOCs) such as malicious IP addresses, suspicious domains, and malware signatures.

In the context of identity-based access control, MISP can provide threat intelligence related to compromised credentials, phishing attacks, or malicious login attempts. By integrating threat intelligence from MISP with SIEM systems, organizations can improve their ability to detect and prevent cyber attacks.

Threat intelligence sharing helps organizations stay informed about emerging threats and implement proactive security measures.

Your College Network Information

The college network consists of multiple interconnected systems that support academic and administrative activities. These systems include student information systems, learning management platforms, library databases, administrative servers, and internet services.

Students, faculty members, and administrative staff access these systems using computers, laptops, and mobile devices connected to the campus network. Because these systems store sensitive information such as student records and academic data, it is important to protect them from unauthorized access.

Implementing context-aware access control in the college network can improve security by verifying user identity, checking device security status, analyzing login location, and evaluating application risk before granting access to resources.

How You Think You Deploy SOC in Your College

A SOC can be deployed in a college environment by implementing centralized monitoring systems that analyze network traffic and user activities. The college IT department can deploy SIEM tools to collect logs from servers, network devices, authentication systems, and applications.

Network monitoring tools and intrusion detection systems can also be used to detect suspicious activities. Security analysts in the SOC can monitor alerts and investigate potential threats such as unauthorized login attempts or malware infections.

By deploying a SOC in the college network, the institution can improve its cybersecurity posture and ensure that sensitive information is protected from cyber threats.

Threat Intelligence

Threat intelligence refers to the process of collecting and analyzing information about potential cyber threats. It helps organizations understand the tactics and techniques used by attackers.

Threat intelligence data includes information about malware, phishing campaigns, suspicious IP addresses, and compromised user accounts. Security teams use this information to improve security controls and detect threats more effectively.

Integrating threat intelligence with SOC and SIEM systems allows organizations to detect emerging threats and respond quickly before they cause damage.

Incident Response

Incident response is the process of identifying, analyzing, and responding to cybersecurity incidents. The main objective of incident response is to minimize damage, restore normal operations, and prevent future attacks.

The incident response process includes several stages such as preparation, detection, containment, eradication, recovery, and post-incident analysis. During a security incident, the SOC team investigates the threat, isolates affected systems, and removes malicious components.

Proper incident response planning ensures that organizations can handle cyber attacks efficiently and maintain system security.

QRadar & Understanding About the Tool

QRadar is a SIEM platform developed by IBM that is widely used for security monitoring and threat detection. QRadar collects logs and security events from multiple sources such as servers, network devices, applications, and security tools.

The platform analyzes this data using advanced analytics and correlation rules to identify suspicious activities and potential cyber threats. QRadar provides dashboards and alerts that help security analysts monitor system security in real time.

By using QRadar, organizations can detect security incidents quickly, investigate threats efficiently, and respond to cyber attacks effectively. QRadar also supports compliance reporting and helps organizations maintain strong security controls.

Conclusion

Stage1:

From web application testing, we understood how vulnerabilities such as SQL injection, cross-site scripting, and authentication issues can affect the security of web applications. Identifying and fixing these vulnerabilities helps improve the security and reliability of applications.

Stage2:

From the Nessus vulnerability report, we learned how automated security scanning tools identify system vulnerabilities and provide detailed information about potential security risks. These reports help organizations prioritize security improvements and strengthen their systems.

Stage3:

From studying SOC, SIEM, and QRadar dashboards, we understood how organizations monitor security events and detect cyber threats in real time. These systems help security teams analyze logs, detect suspicious activities, and respond to incidents quickly to maintain a secure IT environment.

Future Scope

Stage1:

In the future, web application testing will include advanced automated testing tools and artificial intelligence techniques to detect vulnerabilities more accurately and efficiently.

Stage2:

Future vulnerability scanning systems will integrate real-time monitoring, automated remediation, and advanced analytics to improve the speed and effectiveness of vulnerability management.

Stage3:

Future SOC and SIEM systems will use artificial intelligence, machine learning, and advanced threat intelligence to detect complex cyber attacks and improve the overall cybersecurity posture of organizations.

Topics Explored

- Security Operations Center (SOC)
- SOC Cycle
- Security Information and Event Management (SIEM)
- SIEM Cycle
- Threat Intelligence
- Incident Response
- Context-Aware Access Control

Tools Explored

- IBM QRadar
- Nessus Vulnerability Scanner
- MISP Threat Intelligence Platform
- Web Application Security Testing Tools